

authenticated, authorised, and validated based on conditions at the time of access. Continuous verification ensures that trust is not permanent and evaluated for each session or transaction, reducing risks from compromised credentials or insider threats. For example, Microsoft Azure re-evaluates access at every login and during high-risk session changes and Google Cloud verifies identity on every application request (no persistent trust session). The PE evaluates every request, the IdP authenticates identity, and the PEP enforces decisions for each session/request.

Least privilege access: Least privilege ensures that users, applications, and devices operate with restricted permissions, reducing potential damage even if compromised. Instead of broader access rights, granular policies ensure tight control, preventing unauthorised access and lateral movement within systems. The PE determines minimal access policies, while the PA provisions short-lived, restricted access tokens. For example, Amazon Web Services grants access per request using temporary credentials (minutes to hours) and Microsoft Azure provides admin rights only for limited time windows (just-in-time activation).

Identity and contextual awareness: Security decisions are taken beyond simple authentication by evaluating multiple contextual information. Systems assess and evaluate user identity, device health, geolocation, and behavioural patterns to determine risk levels dynamically, making sure access is granted only under safe conditions. The PE determines minimal access policies, while the PA provisions short-lived, restricted access tokens. The PE uses inputs from IdP (identity), CDM (device posture), and TI (risk signals) to make context-based decisions.

Microsegmentation: Microsegmentation limits lateral movement by isolating workloads and services into smaller segments protected by policy enforcement

points. Obviously, even if one segment is compromised, attackers cannot easily access other parts of the network, protecting critical assets. PEPs enforce partitioning boundaries, while the PA configures and updates segmentation policies dynamically. As an example, Microsoft Azure generally enforces rules on every packet/flow between segments and AWS validates traffic for each connection attempt between resources.

Continuous monitoring and analytics: Zero Trust relies on constant visibility into user and scheme activities. Logs, telemetry, and analytics help identify anomalies and suspicious behaviour, enabling organisations to respond quickly to potential threats and breaches. SIEM aggregates log, CDM provides system health data, and TI enriches analytics for real-time detection. Microsoft Azure analyses logs in near real-time with continuous ingestion and AWS evaluates events continuously as activity streams are generated.

Device trust and endpoint security: Devices are evaluated for confirmation before granting access, ensuring they meet security standards such as updated patches and antivirus protection. This reduces risks from compromised or unmanaged endpoints accessing sensitive resources. CDM evaluates device posture, and the PE uses this data to allow or deny access. Interestingly, Microsoft Azure checks device compliance at login and periodically during sessions and Google Cloud verifies device attitude each time access is requested.

Strong authentication (MFA and passwordless): Strong authentication mechanisms like MFA (multi-factor authentication) and passwordless methods add layers of security. These approaches significantly reduce the risk of credential theft and phishing attacks by requiring additional verification factors. The IdP enforces authentication mechanisms (MFA/passwordless), and

the PE validates them during decision-making. Microsoft Azure enforces MFA at every login or when risk level increases mid-session and AWS requires MFA for each privileged or sensitive operation.

Assume breach mentality: This principle shifts the mindset from prevention alone to resilience. By assuming compromise, systems are designed to detect intrusions quickly and contain damage, ensuring attackers cannot move freely or escalate privileges. Microsoft Azure scans resources continuously for vulnerabilities and threats, and Google Cloud performs threat analysis in near real-time across logs and telemetry.

Automation and orchestration: Automation enables rapid response to security incidents, minimising human error and improving efficiency. Orchestrated workflows can detect, analyse, and mitigate threats automatically, ensuring faster containment. SIEM detects anomalies, TI provides threat context, and the PE adapts access decisions accordingly. Microsoft Azure triggers responses instantly when alerts are generated and Amazon Web Services executes remediation in real time upon event detection.

Data-centric security: Zero Trust shifts its focus from network security to data protection. Sensitive data is encrypted, classified, and monitored to ensure it remains secure even if infrastructure is compromised. The SIEM triggers alerts, the PE decides response actions, and the PA executes automated enforcement. Data policies define protection rules, while the PE ensures enforcement during access requests. Amazon Web Services encrypts/decrypts data on every access request and Microsoft Azure evaluates data access policies each time data is accessed or shared.

Secure Access Service Edge (SASE): SASE integrates networking and security into a unified cloud-based model. It enables secure access to